



Lab 9 — Govern the Data: Classification, Minimisation and Protection

Topic 03: Governance Controls Across the AI Lifecycle

Objective: Develop and apply data governance controls for an AI training set, including classification, minimisation, de-identification and retention.

Goal: NovaBank wants to train a churn-prediction model on customer data. You will govern the dataset before a single model is trained: classify every field, strip what is not needed, de-identify what remains, and prove the protection using the Cryptography Toolkit for hashing and encryption.

What you'll build: A governed training dataset specification: a field-by-field classification and minimisation decision, a de-identification method per field, and a tested hashing approach with retention rules.

Tools and data: Customer dataset (customer-training-data.csv, data-dictionary.md), Cryptography Toolkit (<https://alfredang.github.io/cryptography-toolkit/>)

Data files in this lab

- data/customer-training-data.csv
- data/data-dictionary.md
- data/dataset-specification-template.md

Step-by-step

1. Open customer-training-data.csv and data-dictionary.md in labs/lab-09-data-governance/data/. The set has 24 fields and 200 rows of fictional customer records.
2. Classify every field into one of four classes: Direct identifier (NRIC, name, phone, email), Quasi-identifier (postal code, date of birth, gender), Sensitive attribute (income, health flag, religion) or Non-personal (product code, tenure months).
3. Apply minimisation. For each field ask one question: does the churn model actually need this to predict churn? Mark every field Keep, Drop or Transform, and write the reason. Expect to drop at least eight fields.
4. Decide the de-identification method per retained field: remove, hash, generalise (age band instead of date of birth), or keep as is. Record why each method suits that field.
5. Open <https://alfredang.github.io/cryptography-toolkit/> and use the AES section to encrypt a sample customer record. Use AES-256 in CBC mode with a passphrase, and note that the same input with the same key produces recoverable ciphertext.

AES-256 · CBC · passphrase

6. Now test the difference between encryption and hashing for identifiers. Encrypt an NRIC-style string, then decrypt it back. Record that encryption is reversible and therefore still personal data in the hands of the key holder.
7. Use the RSA section to generate a 2048-bit key pair, and note where asymmetric encryption fits in an AI pipeline: protecting keys and data in transit between the data platform and the training environment, not bulk field-level protection.

RSA 2048 · generate key pair

8. Use the ECDSA section to sign a short message and verify the signature. Record how signing gives you dataset integrity — proof that the training set was not altered between approval and training.

ECDSA P-256 · sign then verify

9. Write the retention and deletion rule for the governed dataset: how long the training set is kept, what happens to the model when a customer exercises deletion, and where the audit record of this decision lives.
10. Complete the dataset specification and record the lawful basis you determined for this use in Lab 8, so the data decision and the legal decision live in one document.

Test it

You dropped at least eight fields with a stated reason, every retained personal field has a de-identification method, and you can explain to a business stakeholder why hashing an identifier is not the same as anonymising the record.

Training use only. The organisation, data and individuals in this lab are fictional. Security techniques taught here must only be applied to systems you own or have written authorisation to test.